GUIDE MÉTHODOLOGIQUE

Audit & Sécurisation d'un site WordPress

Une démarche en 9 phases : du diagnostic au maintien en condition de sécurité

Extensions couvertes : UpdraftPlus · Wordfence · Akismet · Cloudflare Turnstile · Contact Form 7 · CF7 Honeypot · WPS Hide Login · Stop User Enumeration · Limit Login Attempts · WP-Optimize

Document de référence interne — Mise à jour : juillet 2026

Sommaire

Introduction & mode d'emploi 3

Phase 0 — Préparation et cadrage 4

Phase 1 — Diagnostic initial (état des lieux) 5

Phase 2 — Sauvegarde d'urgence 7

Phase 3 — Mises à jour & durcissement de la base 8

Phase 4 — Durcissement de l'authentification 10

Phase 5 — Pare-feu & blocage (Wordfence) 11

Phase 6 — Protection anti-spam des formulaires 12

Phase 7 — Optimisation 14

Phase 8 — Vérification, tests & clôture 15

Phase 9 — Maintenance en condition de sécurité 16

Annexe — Récapitulatif des extensions 17

Introduction & mode d'emploi

Ce guide décrit une méthode reproductible pour **auditer puis sécuriser un site WordPress**, en s'appuyant sur les outils gratuits et éprouvés utilisés lors de nos interventions. Il est organisé en **9 phases séquentielles** : chaque phase produit un résultat concret et prépare la suivante. Il peut s'appliquer à un site unique comme à un parc de plusieurs sites (mutualisé OVH, Apache/Linux, MySQL).

La règle d'or : **on ne modifie jamais un site avant d'en avoir une sauvegarde complète et restaurable** (Phase 2). L'ordre des phases n'est pas arbitraire — le sauter expose à une perte de données irréversible.

Comment lire ce guide

- **Phases 0 à 2** — préparer le terrain et se protéger (accès, diagnostic, sauvegarde).
- **Phases 3 à 7** — appliquer les correctifs et le durcissement (mises à jour, authentification, pare-feu, anti-spam, optimisation).
- **Phases 8 à 9** — vérifier, documenter et maintenir dans le temps.

Sécurité — Les clés d'API, identifiants et secrets (Akismet, Cloudflare Turnstile, reCAPTCHA, etc.) présentés dans ce guide sont des **exemples fictifs**. Un secret ne doit jamais être stocké en clair dans une documentation partagée. Conservez-les dans un gestionnaire de mots de passe ou un coffre-fort (Bitwarden, 1Password, HashiCorp Vault) et faites-les tourner (régénération) après toute mission ou tout départ.

Prérequis avant de commencer

Élément	Détail
Accès administrateur WordPress	Compte de rôle « Administrateur » sur chaque site.
Accès serveur	SSH ou SFTP + gestionnaire de fichiers de l'hébergeur (ex. OVH), pour éditer wp-config.php et .htaccess.
Panneau d'hébergement	Pour changer la version de PHP et accéder aux sauvegardes serveur.
Environnement de test (staging)	Copie du site pour tester les mises à jour lourdes sans risque en production.
Compte Cloudflare	Pour générer un widget Turnstile (anti-bot des formulaires).
Gestionnaire de secrets	Pour stocker clés d'API et mots de passe hors documentation.

Phase 0 — Préparation et cadrage

Objectif : réunir les accès, définir le périmètre et se donner un filet de sécurité (staging) avant toute action.

0.1 Définir le périmètre

Listez précisément les sites concernés, leur URL, leur hébergement et leur pile technique. Ce tableau sert de référence tout au long de la mission.

Site	URL	Hébergement	CMS / Pile
Site A	exemple-a.com	OVH mutualisé	WordPress · Apache/Linux · MySQL
Site B	exemple-b.com	OVH mutualisé	WordPress · Apache/Linux · MySQL
Site C	exemple-c.com	OVH mutualisé	WordPress · Apache/Linux · MySQL

0.2 Préparer un environnement de test

La plupart des hébergeurs et certains plugins (ex. WP Staging) permettent de cloner le site. Les **mises à jour lourdes** (PHP, cœur WordPress, thème premium) se testent d'abord sur ce clone. On ne pousse en production qu'une fois le clone validé (pages d'accueil, formulaires, connexion, back-office).

Bonne pratique — Testez toujours un changement de version de PHP ou du cœur WordPress sur un environnement de staging avant la production. C'est la protection la plus efficace contre l'« écran blanc de la mort ».

Phase 1 — Diagnostic initial (état des lieux)

Objectif : dresser un état de sécurité objectif — versions logicielles, comptes, trafic malveillant — et le consigner dans une matrice de vulnérabilités.

1.1 Santé du site & version de PHP

Dans le back-office, ouvrez **Outils → Santé du site → Informations → Serveur**. WordPress y affiche la version de PHP en cours et remonte automatiquement des recommandations de configuration (mémoire, modules manquants, HTTPS, etc.).

À savoir — En 2026, **PHP 8.4** est la version recommandée pour la production : elle est activement maintenue (correctifs de sécurité jusqu'à fin 2028) et offre la meilleure compatibilité avec les extensions majeures. PHP 8.3 reste un choix prudent ; toute version 8.1 ou antérieure est en fin de vie (EOL) et ne reçoit plus de correctifs — à éviter absolument.

1.2 Inventaire des versions : cœur, extensions, thèmes

Rendez-vous dans **Tableau de bord → Mises à jour**, puis dans **Extensions** et **Apparence → Thèmes**. Notez pour chaque élément : version installée, dernière version disponible, état (actif/inactif) et statut de maintenance (abandonné, licence expirée…).

Les points de vigilance récurrents : extensions non mises à jour avec **faille CVE connue**, extensions **abandonnées** (plus d'un an sans mise à jour), thèmes inactifs obsolètes, et extensions **premium à licence expirée** (elles ne reçoivent plus les correctifs de sécurité).

Sécurité — Les extensions et thèmes sont à l'origine de la grande majorité des compromissions WordPress — bien plus que le cœur lui-même. Un composant obsolète, abandonné ou à licence expirée est une porte d'entrée directe. C'est le premier vecteur à traiter.

1.3 Inventaire des accès administrateurs

Recherchez une éventuelle **élévation de privilèges**. Dans **Comptes → Tous les comptes**, filtrez sur le rôle **Administrateur** et vérifiez chaque ligne : chaque administrateur doit correspondre à une personne de confiance identifiée. Tout compte inconnu, générique ou inattendu doit être considéré comme suspect.

- Identifiez les comptes suspects (nom d'utilisateur inconnu, adresse e-mail douteuse, date de création récente non justifiée).
- Ne supprimez pas immédiatement un compte suspect : vérifiez d'abord son contenu (articles, réglages modifiés) et documentez-le, car il peut être la trace d'une intrusion en cours.
- Une fois qualifié, supprimez-le ou rétrogradez-le, puis forcez la réinitialisation des mots de passe des comptes légitimes.

1.4 Scan de malware & analyse du trafic

Installez **Wordfence** (voir Phase 5 pour la configuration complète) et lancez un premier scan des fichiers du cœur, des thèmes et des extensions afin de détecter d'éventuels malwares ou fichiers modifiés. Consultez ensuite **Wordfence → Live Traffic** pour repérer les schémas d'attaque en cours : rafales sur *wp-login.php*, requêtes vers *xmlrpc.php*, pics depuis certaines IP ou certains pays.

1.5 Consigner : la matrice de vulnérabilités

Synthétisez tout le diagnostic dans une matrice classée par criticité. C'est la pièce maîtresse de traçabilité : chaque ligne devra passer au statut « Résolu » à la fin de la mission. Modèle :

Criticité	Vulnérabilité identifiée	Statut cible
Critique	Brute-force actif sur wp-login.php	À bloquer
Critique	Extension X vX.Y — faille CVE connue	Mettre à jour
Critique	Extension abandonnée depuis > 1 an	Désactiver / remplacer
Critique	Extension premium — licence expirée	Renouveler ou remplacer
Critique	Cœur WordPress non à jour	Mettre à jour
Critique	xmlrpc.php exploité	Désactiver
Moyen	Thèmes inactifs obsolètes	Supprimer
Moyen	Extension inutile en production	Désactiver / supprimer
Moyen	Compte administrateur non identifié	Auditer / supprimer
Moyen	Anti-spam mal configuré	Configurer (Phase 6)

Phase 2 — Sauvegarde d'urgence (avant toute modification)

Objectif : préserver une image complète et restaurable du site avant d'y toucher. Elle a une valeur **technique** (rollback) et **légale** (preuve en cas d'incident).

2.1 Installer UpdraftPlus et créer un snapshot complet

1. Installez et activez **UpdraftPlus** (*Extensions → Ajouter*).
2. Ouvrez **Réglages → UpdraftPlus** puis cliquez sur **Sauvegarder maintenant**.
3. Cochez les quatre composants : **base de données + fichiers + extensions + thèmes**, puis lancez la sauvegarde.
4. Une fois terminée, **téléchargez chaque archive en local** (base + plugins + thèmes + uploads + others) et conservez-la hors du serveur.

2.2 Externaliser la sauvegarde

Une sauvegarde qui reste **uniquement sur le serveur** est perdue si le serveur est compromis ou détruit. Configurez un stockage distant (Google Drive, Dropbox, Amazon S3) dans **UpdraftPlus → Réglages**. Sur le long terme, planifiez des sauvegardes automatiques (ex. base quotidienne, fichiers hebdomadaires) avec rétention.

Attention — Sans licence **UpdraftPlus Premium** active, l'envoi automatique vers un stockage distant peut être indisponible — les sauvegardes fonctionnent mais restent locales. Vérifiez ce point, et si la licence est expirée, prévoyez son renouvellement ou un export manuel systématique.

Phase 3 — Mises à jour & durcissement de la base

Objectif : repartir d'une base logicielle saine et à jour (PHP, cœur, extensions, thèmes), supprimer le superflu, puis **automatiser** les mises à jour futures.

À savoir — Ordre recommandé : mettez d'abord à jour le cœur WordPress, les extensions et les thèmes ; changez la version de PHP en dernier, une fois que tout le reste tourne sur le code le plus récent.

3.1 Mettre à jour le cœur, les extensions et les thèmes

1. Vérifiez qu'une **sauvegarde fraîche** existe (Phase 2).
2. Sur le staging : mettez à jour le **cœur WordPress** via *Tableau de bord → Mises à jour*.
3. Mettez à jour **toutes les extensions**, en priorité celles marquées « faille connue » dans la matrice.
4. Mettez à jour **les thèmes actifs**. Pour un thème personnalisé, passez par un **thème enfant** afin de ne pas écraser vos modifications.
5. Testez le site (accueil, formulaires, connexion, back-office), puis reproduisez en production.

Attention — Un thème premium à licence expirée (ex. de type « PRO ») ne reçoit plus ses mises à jour de sécurité tant que la licence n'est pas renouvelée. Tant qu'elle est expirée, le composant reste vulnérable : renouvelez la licence ou remplacez le thème.

3.2 Passer PHP à une version supportée

1. Installez **PHP Compatibility Checker** et scannez le site pour repérer le code incompatible.
2. Sur le staging, basculez la version de PHP vers **8.4** (via le panneau OVH / l'hébergeur) et testez l'intégralité du site.
3. Corrigez ou remplacez les extensions/thèmes incompatibles, puis appliquez en production et surveillez les journaux d'erreurs 24–48 h.

3.3 Supprimer le superflu

- Supprimez (pas seulement désactiver) les **extensions inutiles en production** — même désactivées, elles restent exploitables si elles ont une faille (ex. importeurs de démo, « Hello Dolly »).
- Supprimez les **thèmes inactifs obsolètes**. Ne conservez que le thème actif et un thème par défaut récent (ex. Twenty Twenty-Five) comme secours.

3.4 Activer les mises à jour automatiques

Depuis WordPress 5.5, on active les mises à jour automatiques **composant par composant**, directement dans le back-office :

- **Extensions :** *Extensions → Extensions installées*, colonne *« Mises à jour automatiques »* → **Activer** (possible en action groupée).
- **Thèmes :** *Apparence → Thèmes*, ouvrez chaque thème → **Activer les mises à jour automatiques**.
- **Cœur :** *Tableau de bord → Mises à jour → « Activer les mises à jour automatiques pour toutes les nouvelles versions »*.

Pour un contrôle au niveau serveur, on peut aussi définir dans *wp-config.php* (à placer avant la ligne « That's all, stop editing! ») :

```
/* Mises à jour automatiques du cœur : mineures + majeures */
define( 'WP_AUTO_UPDATE_CORE', true );
```

```
/* OU : uniquement les versions mineures / de sécurité */
// define( 'WP_AUTO_UPDATE_CORE', 'minor' );
```

Bonne pratique — WordPress envoie un e-mail à l'administrateur après chaque mise à jour automatique (réussie ou échouée). Combinez l'automatisation avec des sauvegardes régulières : depuis WordPress 6.x, une extension qui provoque une erreur fatale n'est pas réactivée, mais une sauvegarde reste votre meilleur filet.

Phase 4 — Durcissement de l'authentification

Objectif : réduire la surface d'attaque sur les points de connexion — masquer, limiter, bloquer l'énumération et couper les canaux obsolètes.

4.1 Masquer l'URL de connexion (WPS Hide Login)

Par défaut, la page de connexion est publique et prévisible (*/wp-admin*, */wp-login.php*). L'extension **WPS Hide Login** la remplace par une URL personnalisée et connue de vous seul.

1. Installez et activez **WPS Hide Login**.
2. Dans **Réglages → WPS Hide Login**, définissez une URL non devinable, propre à chaque site :

```
https://exemple-a.com/acces-admin-a-8f2c
https://exemple-b.com/acces-admin-b-3d9e
https://exemple-c.com/acces-admin-c-71ba
```

Bonne pratique — Choisissez un slug unique et aléatoire par site. Conservez ces URL dans votre gestionnaire de secrets, jamais en clair dans une documentation partagée.

4.2 Limiter les tentatives de connexion

Installez **Limit Login Attempts Security** (ou utilisez la protection brute-force de Wordfence — voir Phase 5). L'extension bloque temporairement une IP après un nombre défini d'échecs, et propose la 2FA. Les réglages par défaut conviennent à la plupart des sites ; ne cumulez pas deux extensions qui gèrent le même verrouillage pour éviter les conflits.

4.3 Bloquer l'énumération des comptes (Stop User Enumeration)

Les attaquants énumèrent les identifiants via des URL du type *?author=1* ou l'API REST pour deviner les noms d'utilisateur avant une attaque ciblée. **Stop User Enumeration** détecte et bloque ces tentatives, et journalise les IP fautives. Installez-la et activez-la ; aucun réglage complexe n'est requis.

4.4 Désactiver xmlrpc.php

Le fichier *xmlrpc.php* est un authentificateur ancien, aujourd'hui largement **obsolète**, massivement utilisé comme vecteur de brute-force (amplification) et de déni de service. Sauf besoin explicite (ex. certaines apps mobiles ou pingbacks), désactivez-le.

Méthode simple : une extension dédiée (*« Disable XML-RPC »*). Méthode serveur, en ajoutant dans le *.htaccess* (Apache) :

```
# Bloquer l'accès à xmlrpc.php
<Files xmlrpc.php>
  Require all denied
</Files>
```

4.5 Verrouiller l'édition de fichiers depuis l'admin

Empêchez l'éditeur de thèmes/extensions intégré (qui permettrait d'injecter du code si un compte admin était compromis). Dans *wp-config.php* :

```
define( 'DISALLOW_FILE_EDIT', true );
```

Sécurité — Activez la double authentification (2FA) sur tous les comptes à privilèges (Administrateur, Éditeur). C'est, avec les mises à jour, la mesure au meilleur rapport effort/protection. Wordfence et Limit Login Attempts la proposent nativement.

Phase 5 — Pare-feu & blocage (Wordfence)

Objectif : mettre en place une défense en profondeur — pare-feu applicatif (WAF), scan de malware, protection brute-force et blocage géographique.

5.1 Installer et activer le pare-feu

1. Installez **Wordfence Security** (*Extensions → Ajouter*), puis activez-le.
2. Dans **Wordfence → Firewall**, vérifiez que le **Web Application Firewall** est *« Enabled and Protecting »*.
3. Lancez un **scan complet** (cœur, thèmes, extensions comparés au dépôt officiel) en sensibilité élevée.

5.2 Protection brute-force

Dans **Wordfence → Firewall → All Firewall Options → Brute Force Protection**, activez la protection et réglez les seuils. Les valeurs ci-dessous conviennent à un site à faible nombre d'administrateurs ; assouplissez-les si vous avez de nombreux utilisateurs légitimes.

Paramètre	Valeur recommandée	Remarque
Lock out after how many login failures	**3 à 5**	Wordfence recommande jusqu'à 20 pour de gros parcs d'utilisateurs.
Count failures over what time period	**5 minutes**	Fenêtre de comptage des échecs.
Amount of time a user is locked out	**60 minutes**	Réduit fortement le nombre d'essais quotidiens.
Immediately lock out invalid usernames	**Activé**	Idéal si peu d'administrateurs.
Immediately lock out invalid email addresses	**Activé**	Bloque les tentatives sur e-mails inexistants.
Prevent use of passwords leaked in data breaches	**Activé**	Pour les comptes pouvant publier.

À savoir — Le compromis à trouver : un seuil bas (3) est très strict mais peut verrouiller un utilisateur légitime qui a oublié son mot de passe ; un seuil plus élevé (jusqu'à 20) est plus tolérant. Adaptez au profil du site et gardez un accès SFTP pour vous débloquer si besoin.

5.3 Blocage géographique (Country Blocking)

Dans **Wordfence → Firewall → Blocking → Country Blocking**, bloquez les pays d'où provient un trafic d'attaque et avec lesquels le site n'a aucune relation légitime. Basez-vous sur le *Live Traffic* pour identifier ces origines.

Attention — Le blocage par pays est une fonctionnalité premium de Wordfence. Vérifiez votre licence. Ne bloquez jamais votre propre pays ni ceux de vos visiteurs légitimes, et n'appliquez pas le blocage à l'ensemble du site si des clients internationaux doivent y accéder.

Phase 6 — Protection anti-spam des formulaires (triple couche)

Objectif : empêcher le spam et les injections via les formulaires, en superposant trois défenses complémentaires, plus une validation stricte des champs.

Le principe : chaque couche arrête un type d'attaquant différent. Un bot basique tombe sur le **honeypot** ; un bot avancé est filtré par **Turnstile** ; ce qui passe encore est analysé par l'IA d'**Akismet**.

6.1 Couche 1 — Honeypot (Contact Form 7)

Objectif : piéger les bots basiques avec un champ invisible que seul un robot remplira automatiquement.

1. Installez **Contact Form 7 Honeypot** (ou « CF7 Apps Honeypot »).
2. Ajoutez le shortcode dans le formulaire CF7, juste avant le bouton d'envoi :

```
[honeypot honeypot-field]
```

6.2 Couche 2 — Cloudflare Turnstile

Objectif : bloquer les bots avancés de façon invisible pour l'utilisateur, sans tracking Google.

1. Dans le tableau de bord **Cloudflare**, créez un widget **Turnstile** en mode *« Managed » (invisible)*, en renseignant le domaine du site.
2. Récupérez la **Site Key** et la **Secret Key** (une paire distincte par site) :

```
# Exemples fictifs — à régénérer et à stocker dans un coffre-fort
Site Key   : 0xAAAAAAAA_exemple_site_key
Secret Key : 0xAAAAAAAA_exemple_secret_key
```

3. Installez **Simple Cloudflare Turnstile**, saisissez les clés dans **Réglages → Cloudflare Turnstile**, puis activez l'intégration Contact Form 7.
4. Ajoutez le tag *[turnstile]* dans le formulaire (voir modèle en 6.4).

6.3 Couche 3 — Akismet Anti-Spam

Objectif : filtrer par IA les soumissions spam qui auraient franchi les deux premières couches.

1. Activez **Akismet Anti-Spam** (préinstallé avec WordPress).
2. Obtenez une **clé d'API Akismet** (plan « Personal » pour un site non commercial / éducatif) :

```
# Exemple fictif — ne jamais stocker une vraie clé en clair
API Key : xxxxxxxxxxxx
```

3. Cochez l'option de confidentialité d'Akismet pour rester conforme au **RGPD**.
4. Installez **CF7-Akismet** et, dans **CF7 → onglet Akismet**, mappez les champs : *your-name* → Auteur du commentaire ; *your-email* → E-mail de l'auteur.

6.4 Validation stricte des champs (Contact Form 7)

Limitez ce que chaque champ accepte (longueurs min/max, type) pour réduire la surface d'injection et le bruit.

```
<label> Nom *
  [text* your-name minlength:2 maxlength:60] </label>

<label> Email *
```

```
  [email* your-email autocomplete:email minlength:3 maxlength:254] </label>

<label> Téléphone *
  [tel* your-phone minlength:10 maxlength:15] </label>

<label> Objet
  [text your-subject] </label>

<label> Message
  [textarea your-message minlength:10 maxlength:2000] </label>

[turnstile]
[honeypot honeypot-field]
[submit "Envoyer"]
```

6.5 À propos du score reCAPTCHA (alternative à Turnstile)

Si vous utilisez **reCAPTCHA v3** plutôt que Turnstile, chaque soumission reçoit un score de 0.0 (bot probable) à 1.0 (humain probable). Le seuil par défaut de Google est **0.5**. Le monter à **0.7** durcit le filtrage (0.7 est un seuil courant considéré comme « humain »), au prix de possibles faux positifs. Réglez-le en observant votre trafic réel plutôt qu'en fixant une valeur définitive à l'aveugle.

Phase 7 — Optimisation

Objectif : nettoyer et optimiser la base de données pour de meilleures performances (et une surface plus propre).

7.1 WP-Optimize

1. Installez et activez **WP-Optimize**.
2. Ouvrez l'onglet **Base de données** et vérifiez les opérations proposées (révisions, brouillons auto, tables transitoires, commentaires spam).
3. Lancez les optimisations sélectionnées.

Bonne pratique — Faites toujours une sauvegarde (Phase 2) juste avant une optimisation de base de données. Programmez ensuite un nettoyage automatique périodique dans WP-Optimize, avec une rétention raisonnable des révisions.

Phase 8 — Vérification, tests & clôture

Objectif : prouver que le durcissement fonctionne, mettre à jour la matrice et livrer un rapport traçable.

8.1 Tests de validation

Test	Résultat attendu
Tentatives de connexion répétées avec faux identifiants	IP verrouillée après le seuil défini.
Accès à /wp-admin et /wp-login.php	Redirection / erreur ; seule l'URL masquée fonctionne.
Requête vers xmlrpc.php	Accès refusé (403) ou désactivé.
Énumération ?author=1	Bloquée par Stop User Enumeration.
Envoi d'un payload dans un champ, ex. <script>alert('test')</script>	Rejeté — message « Contenu non autorisé détecté. »
Soumission automatisée (bot) du formulaire	Bloquée par honeypot / Turnstile / Akismet.
Scan Wordfence	Aucun malware ni fichier modifié détecté.

8.2 Clôturer la matrice de vulnérabilités

Reprenez la matrice de la Phase 1 et faites passer chaque ligne au statut « Résolu », « À renouveler » (licences) ou « À surveiller ». Synthétisez l'avant/après :

Indicateur	Avant	Après
Niveau de risque global	Critique	**Modéré / Faible**
Brute-force sur wp-login.php	Actif, non bloqué	**Bloqué**
Extensions à mettre à jour	Plusieurs	**0**
xmlrpc.php	Activé / exploité	**Désactivé**
Sauvegarde automatique	Aucune	**Configurée**
Protection des formulaires	Aucune	**Triple couche**
URL de connexion	/wp-admin public	**Masquée**
Version PHP	Obsolète (EOL)	**8.4 (supportée)**

Phase 9 — Maintenance en condition de sécurité

Objectif : la sécurité est un processus, pas un état. Ce calendrier maintient le site protégé dans la durée.

Fréquence	Action
Hebdomadaire	Vérifier les journaux de connexion et le Live Traffic Wordfence ; ajuster les seuils si besoin.
Hebdomadaire	Lancer un scan Wordfence et confirmer la bonne exécution des sauvegardes distantes.
Mensuel	Contrôler que les mises à jour automatiques se sont appliquées (cœur, extensions, thèmes).
Mensuel	Auditer la liste des comptes administrateurs ; supprimer tout accès non justifié.
Trimestriel	Vérifier les licences (UpdraftPlus, Wordfence, thèmes premium) et les renouveler avant expiration.
Trimestriel	Tester une restauration de sauvegarde sur le staging (une sauvegarde non testée n'en est pas une).
Annuel	Réévaluer la version de PHP et planifier la montée vers une version supportée (ex. 8.5).

Bonne pratique — Testez chaque changement sur le staging avant la production, gardez toujours une sauvegarde récente hors serveur, et ne cumulez jamais deux extensions de sécurité qui gèrent la même fonction (elles entrent en conflit).

Annexe — Récapitulatif des extensions

Extension	Rôle	Phase
UpdraftPlus	Sauvegarde & restauration (locale + distante)	2
PHP Compatibility Checker	Vérifier la compatibilité avant montée de PHP	3
WPS Hide Login	Masquer l'URL de connexion	4
Limit Login Attempts Security	Limiter les tentatives de connexion + 2FA	4
Stop User Enumeration	Bloquer l'énumération des comptes	4
Disable XML-RPC	Couper xmlrpc.php (alternative au .htaccess)	4
Wordfence Security	Pare-feu (WAF), scan malware, brute-force, blocage pays	5
Contact Form 7 Honeypot	Champ piège anti-bot	6
Simple Cloudflare Turnstile	Anti-bot invisible sur les formulaires	6
Akismet + CF7-Akismet	Filtrage IA du spam des formulaires	6
WP-Optimize	Nettoyage & optimisation de la base	7

Fin du guide. *Ce document est une base méthodologique ; adaptez chaque réglage au contexte réel de chaque site (nombre d'utilisateurs, trafic, contraintes métier) et documentez systématiquement vos actions pour la traçabilité et la conformité.*